

INTRODUCTION TO CYBERSECURITY

Date: 09/10/2026

Introduction to cybersecurity:

- Cybersecurity is the practice of protecting computers, networks, applications, devices, and data from unauthorized access, cyberattacks, damage, and theft. Its main goals are to maintain the **confidentiality, integrity, and availability** of information
- Cybersecurity includes identifying risks, preventing attacks, detecting suspicious activity, responding to security incidents, and recovering systems after an attack. Common threats include phishing, malware, ransomware, password attacks, data breaches, and unauthorized access.
- In this field, learners study important areas such as networking, Linux, ethical hacking, cryptography, web security, digital forensics, incident response, and security monitoring. Basic protection includes using strong passwords, enabling multi-factor authentication, updating software, avoiding suspicious links, encrypting sensitive information, and keeping regular backups
- Cybersecurity is important for individuals, businesses, governments, and organizations because modern activities depend heavily on digital systems. A strong cybersecurity program helps protect personal information, financial records, business operations, and critical infrastructure from cyber threats. .

CIA Triad:

- The **CIA Triad** is a basic cybersecurity model consisting of three important principles: **Confidentiality, Integrity, and Availability**.

- **Confidentiality:** Ensures that information is accessible only to authorized people.

Example: Passwords and encryption protect private data.

- **Integrity:** Ensures that information remains accurate, complete, and protected from unauthorized changes.

Example: Preventing an attacker from modifying financial records.

- **Availability:** Ensures that systems and data are accessible to authorized users when needed.

Example: Keeping a website online and restoring it after a cyberattack.

Explanation:

Imagine that you are using a mobile banking application to check your account and transfer money. Confidentiality means that only you can access your account through a password, PIN, or two-factor authentication. Integrity means that your account balance and transaction details remain accurate and no one can change them without permission. Availability means that you can access and use the banking application whenever you need it. In simple words, the CIA Triad ensures that your banking information remains private, correct, and available.

Cyber Threats & Vulnerabilities :

- A **cyber threat** is any possible event, person, or activity that can harm a computer system, network, application, or data. Threats may cause unauthorized access, data theft, data modification, system disruption, or service unavailability. Common examples include malware, phishing, ransomware, insider threats, and denial-of-service attacks
- A **vulnerability** is a weakness or security flaw in software, hardware, a network, configuration, process, or user behavior that an attacker could exploit. Examples

include weak passwords, outdated software, unpatched systems, misconfigured servers, and unsafe application code

● Example: Phishing Attack

- Imagine that a company employee receives an email that appears to come from the company's bank. The email says, "Your account needs verification. Click this link and log in." However, the link leads to a fake website created by an attacker to steal login information.
- The **cyber threat** in this situation is the attacker who sends the fake email and tries to steal the employee's credentials. Phishing is a social-engineering technique in which attackers pretend to be trustworthy people or organizations to trick victims into revealing sensitive information
- The **vulnerability** may be that the employee has not received phishing awareness training, the email security filter does not detect the message, or the account does not use strong multi-factor authentication. A vulnerability is a weakness that can be exploited by a threat source
- When the employee enters the username and password, the attacker may use the stolen credentials to access the company's email or cloud account. The attacker could read confidential emails, send more fake messages, steal files, or use the account to attack other employees. CISA has documented cases in which phishing links were used to collect cloud-service credentials and obtain initial access to accounts
- The company can reduce this risk by training employees to identify suspicious messages, checking links before opening them, enabling phishing-resistant multi-factor authentication, using email filtering, applying least-privilege access, monitoring login activity, and immediately changing compromised passwords. If an employee enters credentials into a fake website, the account should be secured quickly and the affected device should be isolated if malware may have been downloaded

In simple words, the **attacker is the threat**, the employee's lack of awareness or weak security controls are the **vulnerabilities**, the stolen account is the **impact**, and security training, multi-factor authentication, filtering, and monitoring are the **protections**.

Risk and Attack Surface:

Cybersecurity risk is the possibility that a threat will exploit a vulnerability and harm a system, organization, or its data. This harm may include stolen information, altered data, financial loss, service interruption, or reputational damage. NIST describes cybersecurity risk as the potential loss of confidentiality, integrity, or availability.

An **attack surface** is the complete set of points where an attacker may try to enter a system, cause damage, or access data. These points can include websites, open network ports, online applications, email accounts, cloud services, remote-access tools, mobile devices, employees, and third-party connections

For example, imagine a small company with a public website, an online email system, remote desktop access, Wi-Fi, employee laptops, and a cloud storage account. All of these are part of the company's attack surface. If the remote-access service uses weak passwords, that weakness increases the company's risk because an attacker may use it to gain unauthorized access.

The company can reduce its risk by identifying all assets, closing unnecessary ports and services, updating software, using multi-factor authentication, restricting user permissions, monitoring activity, training employees, and regularly testing its systems.

In simple words, **risk is the chance of something going wrong, while the attack surface is all the possible ways an attacker could try to cause that problem**

Types of Hackers:

Hackers are people who use their computer skills to access or test computer systems. Some hackers use these skills to protect systems, while others use them to steal information or cause damage.

-
- A white hat hacker is an ethical hacker. They have permission from a company to test its systems and find security weaknesses. After finding a problem, they report it so the company can fix it.
 - A black hat hacker is a criminal hacker. They access systems without permission to steal data, spread malware, demand money, or damage the system.
 - A gray hat hacker finds security weaknesses without permission but may not have bad intentions. They might report the problem to the owner later. However, entering a system without permission can still be illegal.
 - A script kiddie is someone with limited technical knowledge who uses ready-made hacking tools or scripts created by others. Even if they do not fully understand the tools, they can still cause serious damage.
 - A hacktivist uses hacking to support a political or social cause. For example, they may attack or deface a website to spread a message.
 - A state-sponsored hacker works for or is supported by a government. Their goal may be to collect secret information, spy on another country, or attack important systems.
 - An insider threat comes from someone inside an organization, such as an employee or contractor. This person may intentionally steal information or accidentally expose it.

In simple words, white hat hackers help protect systems, black hat hackers harm or misuse systems, and gray hat hackers test systems without proper permission. The most important difference is whether the hacker has authorization to access or test the system.

Cybersecurity Domains and Teams:

Cybersecurity is divided into different domains that focus on protecting an organization's systems, networks, applications, data, and users. Some areas focus on prevention, while others focus on testing, detecting, and responding to attacks. Penetration testing, red teaming, blue teaming, purple teaming, and Security Operations Centers are important parts of the cybersecurity field.

1. Security and Risk Management

Security and risk management focuses on identifying and controlling cybersecurity risks. Organizations create security policies, assess possible threats, follow legal requirements, and decide how much protection their systems need. For example, if a company faces a high risk of ransomware, it may invest in employee awareness training, strong backups, and advanced security tools.

2. Asset Security

Asset security protects important organizational assets such as customer data, employee information, laptops, servers, databases, and confidential files. This domain determines who owns the data, who can access it, how long it should be stored, and how it should be securely deleted. Proper asset security helps prevent sensitive information from being lost, stolen, or misused.

3. Security Architecture and Engineering

Security architecture and engineering focuses on designing systems with security built into them from the beginning. Professionals in this area use encryption, secure system design, network separation, firewalls, and defense-in-depth strategies. For example, a bank may encrypt customer information and store highly sensitive systems on a separate network.

4. Communication and Network Security

Communication and network security protects data as it travels between computers, devices, and networks. It includes firewalls, VPNs, secure Wi-Fi, intrusion detection systems, and network segmentation. For example, when an employee connects to a company network from home, a VPN can help protect the connection from unauthorized monitoring.

5. Identity and Access Management

Identity and access management, often called IAM, ensures that only authorized people can access specific systems and information. It includes passwords, multi-factor authentication, access permissions, account management, and privileged-access management. For example, an employee may be allowed to access only their department's files, while a system administrator may have broader access.

6. Security Assessment and Testing

Security assessment and testing is used to find weaknesses before real attackers discover them. Security professionals perform vulnerability scans, security audits, configuration reviews, and penetration tests. These activities help organizations understand whether their security controls are working properly and what improvements are needed.

7. Penetration Testing

Penetration testing, or pen testing, is an authorized and controlled attempt to attack a system, network, website, or application. Ethical hackers use techniques similar to real attackers to identify and prove security weaknesses. A penetration test normally has a defined scope, target, and time limit, such as testing a company's web application or external network. The goal is to discover vulnerabilities and provide recommendations for fixing them.

8. Red Teaming

Red teaming is a broader and more realistic security exercise in which a red team simulates a real-world attacker. The team may use technical exploitation, phishing, social engineering, physical security testing, and other methods to reach a specific objective. Unlike a normal penetration test, red teaming often tests not only technology but also people, processes, monitoring, and incident-response capabilities. Red teams are the offensive side of a security exercise, while blue teams are responsible for defending the organization.

9. Blue Teaming

Blue teaming focuses on defending an organization from cyberattacks. Blue team members monitor systems, investigate alerts, identify suspicious behavior, block attacks, fix vulnerabilities, and improve security controls. They may manage firewalls, endpoint protection, security tools, access controls, and incident-response procedures. In a red team exercise, the blue team tries to detect and stop the simulated attack.

10. Security Operations Center

A Security Operations Center, commonly called a SOC, is a team or facility responsible for continuously monitoring and protecting an organization's technology environment. SOC analysts review security alerts, investigate suspicious activity, analyze logs, detect malware and phishing, and respond to incidents. A SOC often uses tools such as SIEM, EDR, threat-intelligence platforms, and network-monitoring systems. In many organizations, the SOC performs the daily defensive work of the blue team

11. Purple Teaming

Purple teaming is a collaborative approach in which red team and blue team members work together to improve security. The red team demonstrates an attack technique, while the blue team checks whether it can detect and respond to that technique. Both teams then discuss the results and improve detection rules, security controls, and response procedures. Purple teaming helps organizations turn offensive testing into practical defensive improvements.

12. Security Operations

Security operations includes the daily activities required to monitor, detect, investigate, and respond to cyber threats. It is closely connected to SOC and blue team functions. Security operations professionals analyze alerts, investigate incidents, perform threat hunting, manage security tools, and help prevent similar attacks in the future.

13. Software Development Security

Software development security focuses on creating secure applications. Developers use secure coding practices, conduct code reviews, scan source code, and test applications for vulnerabilities before release. Security is included throughout the software development life cycle so that weaknesses can be fixed early. This area is also known as application security or DevSecOps.

14. Incident Response

Incident response is the process of handling a cybersecurity incident from beginning to end. When an attack occurs, the response team identifies what happened, contains the threat, removes the attacker or malware, restores affected systems, and documents the lessons learned. For example, after a phishing attack, the team may disable a compromised account, remove malicious emails, check affected systems, and reset passwords.

15. Digital Forensics

Digital forensics involves collecting and analyzing evidence from computers, servers, mobile devices, cloud systems, and networks. Investigators use forensics to understand how an attack happened, what data was affected, and who or what was responsible. Digital forensic evidence may also be used in legal investigations, internal disciplinary cases, or regulatory reporting.

16. Business Continuity and Disaster Recovery

Business continuity and disaster recovery help an organization continue operating or recover quickly after a cyberattack, hardware failure, power outage, or natural disaster. This area includes backups, recovery procedures, alternate systems, emergency communication plans, and recovery testing. For example, a company affected by ransomware can restore its operations from clean and properly tested backups.

17. Legal, Regulatory, and Compliance Security

This domain ensures that an organization follows cybersecurity laws, privacy regulations, contracts, and industry standards. It includes audits, compliance assessments, security documentation, data-protection requirements, and reporting obligations. For example, a healthcare organization must protect patient information, while a financial company must follow strict rules for protecting customer and transaction data.

How These Areas Work Together?

A real security operation usually combines several domains. The **red team** simulates an attack, the **blue team and SOC** monitor and defend the environment, and the **purple team** helps both sides learn from the exercise. **Penetration testing** finds technical weaknesses, while **incident response and digital forensics** handle real incidents. Risk management, secure architecture, IAM, network security, application security, and compliance provide the foundation that supports all of these activities.